

Information Security Policy

Agentic Voice, Inc. — d/b/a MFunding.net | Momentum Funding

Document	Information Security Policy (ISP)
Version	1.0
Effective Date	July 28, 2026
Next Review	July 28, 2027 (annual)
Owner / Approver	Ernesto Lee, Chief Executive Officer & Security Officer
Applies To	All personnel, contractors, systems, and data of Agentic Voice, Inc.

1. Purpose & Scope

This Information Security Policy ("Policy") defines how Agentic Voice, Inc. ("the Company," "we") protects the confidentiality, integrity, and availability of the information it collects, processes, and stores — with particular emphasis on the consumer and business financial data handled as part of our business-financing brokerage operations. The Policy applies to all Company systems, applications, cloud services, employees, officers, and independent contractors who access Company data or systems.

The Company operates a web application (mfunding.net and the merchant portal at my.mfunding.net) that helps small businesses apply for working capital and other financing products. As part of application intake, the Company may — with the applicant's explicit consent — connect the applicant's business bank account through Plaid Inc. to evaluate banking activity. Protecting this data is the central objective of this Policy.

2. Roles & Responsibilities

Role	Responsibility
Security Officer (Ernesto Lee, CEO)	Owns this Policy; approves exceptions; ensures MFA, access reviews, monitoring, and incident response are performed; approves vendors that process regulated data.
Administrators (super_admin / admin)	Configure systems securely, manage user access on a least-privilege basis, respond to monitoring alerts and incidents.
Staff & Contractors (employee, closer)	Follow this Policy and the Acceptable Use section; use only the access granted to them; report suspected security events immediately.
Application users (user / merchants)	Access is scoped to their own records only, enforced by database row-level security.

3. Data Classification

The Company classifies data into three tiers; controls scale with sensitivity.

Classification	Examples	Handling
Restricted	Consumer/business bank data obtained via Plaid (transactions, statements, balances, account & routing numbers), Plaid access tokens, applicant PII (name, contact, EIN), funding-application financials.	Encrypted in transit and at rest; access strictly least-privilege; secrets stored in an encrypted vault; never exposed to the browser; never sold.
Internal	Deal pipeline records, funder/lender records, internal messages, operational dashboards.	Access limited to authenticated staff by role; row-level security enforced.
Public	Marketing website content, published policies.	No access restriction; integrity controlled through change management.

4. Access Control

The Company enforces a documented access-control standard built on least privilege and role-based access.

- **Role-based access control (RBAC).** Application access is governed by a defined set of roles (user, closer, employee, admin, super_admin) enforced in the database. Every table in the production database has row-level security (RLS) enabled, so each account can reach only the records its role permits; merchant users can reach only their own records.
- **Centralized identity.** Application authentication is centralized through Supabase Auth. Administrative access to the underlying platforms (Supabase, GitHub, Google Workspace, Netlify, GHL, Plaid) is controlled through each provider's own account and identity management.
- **Least privilege.** Users and non-human integrations receive the minimum access required for their function. Non-human/service authentication uses bearer tokens (service-role JWTs) and TLS, and the credentials are held in an encrypted secrets vault rather than in code.
- **Onboarding.** New personnel are granted access only to the systems and role level their duties require, approved by the Security Officer.
- **Offboarding / deprovisioning.** Upon termination or role change, the individual's access is revoked **immediately** — application role downgraded/disabled, and provider accounts (GitHub, Google Workspace, Supabase, GHL, Netlify, Plaid) removed or disabled the same day.
- **Periodic access reviews.** The Security Officer reviews all accounts and their privilege levels **quarterly** to confirm least privilege and remove stale access. This review is scheduled as a recurring operational task so it is not dependent on memory.

5. Authentication & Multi-Factor Authentication

- **Critical administrative systems require multi-factor authentication (MFA).** MFA is required for all administrative accounts on Supabase, GitHub, Google Workspace, GHL, and Netlify.
- Application users authenticate through Supabase Auth using email and password / email verification.
- Passwords and authentication secrets are never stored in source code or shared in plaintext; provider-managed credential storage is used throughout.

6. Encryption

- **In transit:** All traffic to the website, portal, API, and edge functions is served over HTTPS with **TLS 1.2 or higher**, enforced by our hosting (Netlify) and backend (Supabase) providers. HTTP is redirected to HTTPS and security response headers (X-Frame-Options, X-Content-Type-Options, Referrer-Policy) are applied.
- **At rest:** The production database and file storage are encrypted at rest using **AES-256** by the managed Supabase platform.
- **Secrets:** API keys and third-party credentials (including Plaid client secrets and Plaid access tokens) are stored in an **encrypted secrets vault** and as protected edge-function secrets. Plaid access tokens are exchanged and used only server-side, stored encrypted (referenced by a vault identifier, never in plaintext columns), and are never returned to the browser.
- **Server-side integrations:** All third-party API calls (Plaid, GHL, and others) are made from server-side edge functions, never from the client, so credentials are never exposed to end users.

7. Vendor & Third-Party Management

The Company relies on established, independently audited service providers and reviews their security posture before use.

Vendor	Function	Assurance
Plaid Inc.	Bank account connection & transaction data	SOC 2; handles bank credentials directly (we never see them)
Supabase	Database, auth, storage, edge functions, secrets vault	SOC 2 Type II; encryption at rest & in transit
Netlify	Web application hosting / CDN / TLS	SOC 2; managed TLS & platform patching
GoHighLevel (GHL)	CRM, messaging	SOC 2; vendor-managed platform

Vendors that process Restricted data must maintain industry-standard security certification (e.g., SOC 2). Data shared with funding partners is limited to the application details the applicant submits for the purpose of obtaining financing they requested.

8. Monitoring, Logging & Incident Response

- **Automated monitoring.** An automated system-health check runs **every 10 minutes**, probing critical services and dependencies. On any state transition (a service going down or recovering) it opens/closes an incident record and **emails the Security Officer**, with a task-board fallback so alerts are never lost.
- **Audit trail.** Security-relevant application actions (including bank-connection events) are recorded to an activity/audit log; database and platform logs are retained by the managed providers.
- **Incident response.** On a suspected security incident the Security Officer will: (1) contain — revoke affected credentials/tokens and disable affected access; (2) assess scope and root cause using logs and the audit trail; (3) remediate and restore service; (4) document the incident and corrective actions.
- **Breach notification.** If an incident involves unauthorized access to consumer financial or personal data, the Company will notify affected individuals and applicable parties (including Plaid and regulators) as required by applicable law and contractual obligations, without undue delay.

9. Change Management

- All application code is version-controlled in Git with a full, attributable change history.
- Changes pass an automated **TypeScript type-check gate** as part of the build before deployment, and are reviewed before release to production.
- **Dependency vulnerability scanning** is enabled on the source repository (GitHub Dependabot alerts plus automated security-update pull requests). Platform and OS-level patching for hosting and database infrastructure is managed by Netlify and Supabase; company endpoints receive operating-system security updates automatically.

10. Acceptable Use

- Company systems and data are used only for authorized business purposes.
- Credentials are never shared; each user uses their own account.
- Restricted data is never copied to unmanaged devices, personal email, or unauthorized third-party tools.
- Devices used to access Company systems must have current operating-system security updates and screen-lock enabled.
- Suspected security events must be reported to the Security Officer immediately.

11. Policy Governance & Review

This Policy is reviewed and updated at least **annually**, and after any material change to the Company's systems, data handling, or a significant security incident. The Security Officer approves all revisions and increments the version number. Exceptions require written approval from the Security Officer.

Approved and adopted on behalf of Agentic Voice, Inc.:

Ernesto Lee — Chief Executive Officer &
Security Officer

Date

Agentic Voice, Inc. d/b/a MFunding.net | Momentum Funding — Information Security Policy v1.0 — Confidential. This document describes controls in effect as of the effective date and is maintained under version control.